

Security Lab GRC Documentation

Zero Trust Architecture Alignment



America's Cyber Defense Agency
NATIONAL COORDINATOR FOR CRITICAL INFRASTRUCTURE SECURITY AND RESILIENCE



Created By: Paul Leone
April 6, 2026



Table of Contents

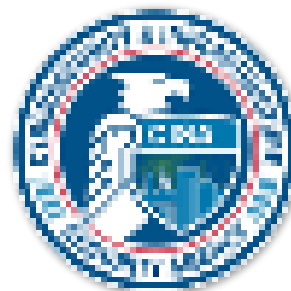
CISA Zero Trust Maturity Model v2.0 Alignment	2
Version 2.0: Change Log (from v1.0, January 2026)	2
Zero Trust Architecture Implementation Overview	4
Zero Trust Pillar Implementation.....	4
5.1 Identity (CISA ZTMM Table 2) : Maturity: Advanced	4
5.2 Devices (CISA ZTMM Table 3) : Maturity: Advanced	7
5.3 Networks (CISA ZTMM Table 4) : Maturity: Advanced	9
5.4 Applications and Workloads (CISA ZTMM Table 5) : Maturity: Advanced	11
5.5 Data (CISA ZTMM Table 6) : Maturity: Advanced	13
Cross-Cutting Capabilities (CISA ZTMM Table 7)	15
Zero Trust Maturity Summary	16
Version History	20



CISA Zero Trust Maturity Model v2.0 Alignment

Document Control:

Version:	2.0
Last Updated:	April 2026
Owner:	Paul Leone
Prior Version:	1.0: January 2026
Overall Maturity:	Advanced (Stage 3 of 4): 87% of functions at Advanced or higher



Version 2.0: Change Log (from v1.0, January 2026)

Cloud workload content integrated directly into each pillar section. Cloud node inventory: AWS (2 : Amazon Linux 2 EC2 t3.micro, Windows Server 2025 EC2 c7i-flex.large), Azure (2 : Ubuntu 24.04 LTS Standard_B2ats_v2, Windows Server 2025 Standard_E2s_v3 Spot), GCP (2 : Debian 13.4 e2.micro, Ubuntu e2.micro), 6 nodes total via Tailscale WireGuard mesh VPN. No public management ports on any cloud node.

Pillar	Subcategory	Change	Impact
Identity	Authentication	Tailscale device-bound WireGuard key authentication added as phishing-resistant MFA equivalent for all 6 cloud nodes. Windows cloud nodes subject to domain Kerberos. Cloud console access enforces provider MFA independently. SSH key-only for all Linux cloud nodes (passwords disabled globally via Ansible).	Advanced
Identity	Identity Stores	Cloud IAM identity stores added: AWS IAM instance profiles, GCP service accounts (minimal roles, no owner/editor on Compute), Azure Entra ID (domain-synced accounts). Cloud node accounts tracked in Authentik/AD with 45-day dormancy review.	Advanced
Identity	Risk Assessments	Cloud-native identity risk added: Azure Sentinel KQL sign-in anomaly detection; AWS GuardDuty CredentialAccess findings; GCP SCC IAM anomaly detection. All cloud findings forwarded to on-premises Splunk.	Advanced
Devices	Policy Enforcement	Wazuh CIS SCA extended to all 6 cloud nodes daily. CIS policies: Amazon Linux, Debian 12/13, Ubuntu 22.04/24.04, Windows Server 2025. AWS Inspector, GCP SCC, Azure Defender for Cloud provide supplemental scanning. Critical less than 72h MTTR maintained across all 31+ endpoints.	Advanced
Devices	Threat Protection	ClamAV on 4 Linux cloud nodes; Microsoft Defender on 2 Windows cloud nodes.	Advanced



		GuardDuty, SCC, Azure Defender for Cloud behavioral detection supplement signature-based tools.	
Networks	Segmentation	Cloud segmentation added: AWS VPC (172.31.0.0/16), GCP VPC (10.128.0.0/16), Azure VNet (10.130.0.0/16) isolated from each other. Tailscale ACL default-deny mesh. GCP firewall policy with Google Threat Intelligence blocking (TOR exit nodes, malicious IPs, sanctioned countries at priority 100-130).	Advanced
Networks	Traffic Encryption	Tailscale WireGuard (ChaCha20-Poly1305) added as mandatory cloud management transport. AWS S3 SSE for CloudTrail. GCP persistent disk and GCS default encryption. Azure Managed Disk and Log Analytics encrypted at rest. No plaintext management paths on any cloud node.	Advanced
Networks	Visibility	AWS VPC flow logs, GCP VPC flow logs, Azure NSG flow logs added to unified SIEM. GCP Cloud Armor access logs capture WAF events. All cloud flow data supplements on-premises pfSense/Suricata data.	Advanced
Applications	Application Access	Tailscale ACL gates all cloud node access (device-bound, default-deny). GuardDuty, SCC, and Sentinel findings auto-create TheHive cases via Shuffle SOAR.	Advanced
Applications	Threat Protections	GCP Cloud Armor three-tier WAF/DDoS (SQLi/XSS blocking via v33-stable expression sets). Azure DDoS Protection plan homelab-ddos. AWS Security Hub application-layer misconfiguration detection.	Advanced
Data	Inventory	Cloud data inventory: AWS S3 CloudTrail buckets (SSE, 90-day lifecycle), GCP GCS buckets (default encryption), Azure Log Analytics homelab-log (90-day retention). Classified: Confidential (audit logs), Internal (telemetry). Wazuh FIM on all 6 cloud nodes.	Advanced
Data	Encryption	Cloud encryption at rest: AWS S3 SSE, GCP persistent disk default encryption, Azure Managed Disk encryption. All cloud management traffic: Tailscale WireGuard (ChaCha20-Poly1305). No plaintext paths.	Advanced
Visibility	Collection	AWS CloudTrail, GCP Admin Activity/Data Access logs, Azure Activity Log/Monitor added. Wazuh agents on 6 cloud nodes forward to on-premises Splunk. Cloud logs: 90-day retention matching on-premises SIEM policy.	Advanced
Automation	Orchestration	Wazuh Active Response extended to 6 cloud nodes via Tailscale (firewall-drop, host-deny,	Advanced



		account-disable). GuardDuty and Sentinel incidents auto-create TheHive cases via Shuffle. Ansible cloud rebuild RTO less than 2 hours validated.	
Governance	Policies	Cloud policies added: no public management ports, Tailscale-only access, CIS SCA via Wazuh, IAM least-privilege per provider. AWS Security Hub, GCP SCC security health, Azure Defender for Cloud Secure Score provide cloud governance metrics.	Advanced

Zero Trust Architecture Implementation Overview

This cybersecurity lab demonstrates comprehensive Zero Trust Architecture (ZTA) principles aligned with NIST SP 800-207 and CISA Zero Trust Maturity Model v2.0. The implementation achieves Advanced maturity (Stage 3 of 4) across core Zero Trust pillars through explicit verification of every access request, least-privilege enforcement via RBAC, assume-breach mentality with continuous monitoring, and encrypt-everything policies using modern cryptographic standards. Version 2.0 extends ZTA scope to a hybrid multi-cloud architecture spanning AWS, Azure, and GCP with 6 cloud nodes integrated into the same enforcement model applied to on-premises infrastructure.

CISA Zero Trust Maturity Level: Advanced (Stage 3 of 4)

Maturity stages: Traditional (manual configurations, static policies), Initial (starting automation, aggregated visibility), Advanced (automated controls, centralized visibility, risk-based least privilege, pre-defined mitigations), Optimal (fully automated just-in-time lifecycles, dynamic policies, comprehensive situational awareness).

Zero Trust Pillar Implementation

5.1 Identity (CISA ZTMM Table 2) : Maturity: Advanced

Subcategory	Implementation	Status
Authentication	Agency authenticates all identity using phishing-resistant MFA (FIDO2/PIV initiating implementation) with continuous validation. Authentik SSO enforces TOTP MFA for 100% administrative accounts with OAuth2/OIDC integration. SSH access uses Ed25519 certificate-based authentication validated via Step-CA PKI. MFA required for VPN access (Tailscale device authentication). Cloud extension: SSH key-only authentication on all 4 Linux cloud nodes (passwords disabled globally via Ansible). Windows cloud nodes authenticate via domain Kerberos over Tailscale (same AD Group Policy	Advanced



	as on-premises). Cloud console access (AWS, GCP, Azure) enforces provider MFA independently. Tailscale device-bound WireGuard key serves as phishing-resistant MFA equivalent for all cloud management access.	
Identity Stores	Authentik provides centralized identity management with LDAP/SAML/OAuth2 integrations across hybrid environments. SSO implemented for 90% of web services via Traefik ForwardAuth middleware. Cloud extension: AWS IAM instance profiles (no long-lived access keys), GCP service accounts (minimal roles, no owner/editor on Compute), Azure Entra ID accounts (domain-synced via AD over Tailscale) integrated into identity lifecycle. All cloud node local user accounts tracked via Wazuh agent inventory and subject to 45-day dormancy review.	Advanced
Risk Assessments	Splunk correlates failed authentication patterns, geoIP anomalies, impossible travel scenarios, and behavioral baselines. Wazuh monitors account lifecycle events with automated alerts. TheHive case creation triggered by identity risk threshold violations. Cloud extension: Azure Sentinel KQL rule detects sign-in from new geographic location. AWS GuardDuty CredentialAccess findings trigger TheHive cases via Shuffle SOAR. GCP SCC IAM anomaly detection identifies over-permissive service account usage. All cloud identity risk findings forwarded to on-premises Splunk for unified correlation.	Advanced
Access Management	Authentik enforces 30-minute session timeouts with automatic re-authentication. SSH sessions use temporary sudo elevation with explicit justification. OAuth2 scopes limit permissions to minimum required. Account access reviews conducted quarterly. Cloud extension: no persistent elevated privileges on cloud nodes. AWS IAM instance profiles provide minimum required actions only. GCP service accounts use minimal roles. Azure RBAC scoped per resource group. Cloud node sudo elevation logged to	Advanced



	SIEM via Wazuh. Tailscale ACL enforces per-session, per-node explicit allow rules.	
Visibility and Analytics	100% authentication event logging forwarded to dual SIEM. Behavioral analytics detect unusual login times, geographic anomalies, credential stuffing, and privilege abuse. Real-time correlation identifies compromised credentials within 5 minutes of suspicious activity. Cloud extension: AWS CloudTrail IAM events, GCP Admin Activity logs, Azure Activity Log augment on-premises authentication telemetry. Cloud authentication events forwarded to on-premises Splunk via Wazuh agents for unified behavioral analysis across all 31+ endpoints.	Advanced
Automation and Orchestration	Standard user provisioning/deprovisioning automated via Authentik workflows. Privileged account management requires manual approval with automated expiration. SSH key distribution centralized via Ansible with automated rotation. Cloud extension: cloud node SSH key distribution automated via Ansible; Windows cloud node account lifecycle managed via AD GPO over Tailscale; cloud IAM role assignments documented with quarterly review; Wazuh agent reinstallation automated for cloud node recovery.	Advanced
Governance	CIS Benchmark password policies enforced (14-char minimum non-MFA, 8-char with MFA). MFA enforcement policies updated monthly. Quarterly access reviews validate RBAC group assignments. Cloud extension: no long-lived access keys on EC2, no owner/editor role on GCP Compute service accounts, Azure admin access requires MFA via Entra Conditional Access. Cloud node CIS SCA compliance tracked in Wazuh dashboard alongside on-premises.	Advanced
Gap to Optimal	Full automation of privileged identity orchestration, continuous identity risk scoring, just-in-time access for all accounts, behavior-based analytics across all systems, dynamic policy updates without manual intervention. Cloud-specific: Azure Spot eviction automation	Initial



pending; cross-provider identity federation not formally documented.

5.2 Devices (CISA ZTMM Table 3) : Maturity: Advanced

Subcategory	Implementation	Status
Policy Enforcement and Compliance Monitoring	Wazuh agents (25+ on-premises endpoints) provide real-time compliance validation against CIS Benchmarks (92-98% compliance). Nessus authenticated scans monthly. Ansible enforces configuration baselines with drift detection. Virtual asset compliance (50+ containers, 30+ VMs) monitored via Proxmox and Docker health checks. Cloud extension: Wazuh CIS SCA on all 6 cloud nodes daily : CIS Amazon Linux, Debian 12/13, Ubuntu 22.04/24.04, Windows Server 2025. Ansible hardening playbooks applied to all 4 Linux cloud nodes via SSH over Tailscale. Windows cloud nodes subject to same GPO baselines via domain join over Tailscale.	Advanced
Asset and Supply Chain Risk Management	PatchMon tracks 5,000+ packages across 30+ hosts with daily NVD CVE correlation. Container image verification via SHA-256. Package signature validation (GPG keys) for all installations. Limited SBOM tracking (Trivy/Grype planned Q2 2026). Cloud extension: cloud node base images tracked by version. PatchMon on 4 Linux cloud nodes with daily CVE correlation. WSUS manages 2 Windows cloud nodes. AWS Inspector, GCP SCC, Azure Defender for Cloud supplement Wazuh.	Advanced
Resource Access	Authentik ForwardAuth validates device compliance before granting application access. Step-CA certificates authenticate devices for service-to-service communication. Wazuh compliance status integrated into access control decisions. Non-compliant devices restricted to remediation VLAN. Cloud extension: Tailscale device-bound WireGuard key is the device compliance gate for cloud node access. Wazuh compliance status visible for cloud nodes in same dashboard as on-premises. Non-	Advanced



	compliant cloud nodes flagged for Ansible remediation.	
Device Threat Protection	Wazuh EDR provides FIM, rootkit detection, and vulnerability assessment. ClamAV (Linux) and Microsoft Defender (Windows) with centralized management. Suricata/Snort network IDS. YARA rules with Cortex multi-engine analysis. Wazuh Active Response automated containment. Cloud extension: Wazuh FIM and rootkit detection on all 6 cloud nodes. ClamAV on 4 Linux cloud nodes; Microsoft Defender on 2 Windows cloud nodes updated via WSUS. GuardDuty, GCP SCC, Azure Defender for Cloud behavioral detection supplement signature-based tools.	Advanced
Visibility and Analytics	Real-time asset discovery via NetAlertX, Checkmk, and Prometheus node exporters. Endpoint telemetry (Sysmon process trees, network connections, file modifications) forwarded to SIEM. Cloud extension: all 6 cloud nodes enrolled in Checkmk via Tailscale. AWS CloudWatch Agent, GCP Cloud Monitoring Ops Agent, Azure Monitor VM metric alert rules (7 active) provide cloud device metrics. Cloud node lifecycle events tracked via provider audit logs.	Advanced
Automation and Orchestration	Proxmox automation provisions VMs with pre-configured baselines. Docker/Watchtower auto-updates containers. WSUS automated patch approval. Ansible playbooks remediate drift with snapshot-before-patch. Cloud extension: Ansible new_install_baseline_roles.yml provisions cloud nodes from scratch with CIS baselines. WSUS manages Windows cloud node patching automatically. Wazuh Active Response on cloud nodes executes containment via Tailscale. Cloud node rebuild RTO less than 2 hours validated.	Advanced
Governance	Lifecycle policies define procurement standards, configuration baselines, monitoring requirements, and decommissioning procedures. CIS Benchmark policies enforced via Wazuh SCA with quarterly reviews. Vulnerability remediation	Advanced



	SLAs (Critical less than 72h, High less than 7d) tracked via TheHive. Cloud extension: cloud node decommissioning runbooks documented (SSH key removal, Tailscale revocation, IAM role cleanup). Azure Spot Deallocate policy and restart procedure documented. Cloud patch SLAs enforced identically to on-premises.	
Gap to Optimal	Fully automated provisioning, monitoring, isolation, remediation, deprovisioning; comprehensive real-time device risk analytics; complete SBOM tracking. Cloud-specific: SBOM (Trivy/Grype) planned Q2 2026; Azure Spot eviction automation pending.	Initial

5.3 Networks (CISA ZTMM Table 4) : Maturity: Advanced

Subcategory	Implementation	Status
Network Segmentation	3-tier architecture (DMZ, application, backend) with VLAN isolation per service criticality. pfSense/OPNsense enforce default-deny firewall rules. Traefik reverse proxy provides ingress micro-perimeter. Critical workloads (SIEM, authentication, PKI) on dedicated VLANs. Cloud extension: AWS VPC (172.31.0.0/16), GCP VPC (10.128.0.0/16), Azure VNet homelab-vnet2 (10.130.0.0/16) each isolated from other providers. Tailscale ACL enforces explicit allow rules between all nodes (default deny). GCP VPC firewall policy (homelab, 17 rules) with Google Threat Intelligence blocking at priority 100-130. GCP Cloud Armor three-tier WAF/DDoS.	Advanced
Network Traffic Management	Application profiles defined for web services, databases, DNS, monitoring, and administrative access. pfSense traffic shaping prioritizes critical services. Traefik load balancing based on health checks. Periodic monthly reviews. Cloud extension: AWS Security Group rules version-controlled in Terraform. GCP VPC firewall policy rules managed via Terraform with plan review. Azure NSG rules managed via ARM template. Cloud traffic management reviewed monthly alongside on-premises.	Advanced



Traffic Encryption	TLS 1.3 mandatory for all web services via Traefik. SSH encrypted with AES-256-GCM/Ed25519. VPN encryption via WireGuard (ChaCha20) and OpenVPN (AES-256). Syslog-ng TLS encrypts log transmission. Step-CA PKI with 90-day certificate rotation. DNSSEC. Cloud extension: Tailscale WireGuard (ChaCha20-Poly1305) mandatory for all cloud management traffic. AWS S3 SSE for CloudTrail logs. GCP persistent disk and GCS default encryption. Azure Managed Disk and Log Analytics encrypted at rest. No plaintext management paths across any cloud provider.	Advanced
Network Resilience	HA firewall cluster (pfSense CARP) with less than 5-second failover. Dual Unbound/Technitium DNS with 99.9% availability. Dual SIEM (Splunk + Elastic). Redundant internet connections. Traefik load balancing. Cloud extension: Tailscale subnet router redundancy via dual on-premises pfSense nodes. Cloud nodes distributed across 3 independent providers (AWS, GCP, Azure). Azure DDoS Protection plan homelab-ddos. GCP Cloud Armor multi-tier DDoS mitigation.	Advanced
Visibility and Analytics	100% network traffic visibility via pfSense flow logs, Traefik access logs, Unbound DNS query logs, Suricata/Snort IDS. Real-time correlation detects port scans, DGA domains, DNS tunneling, C2 beacons. MISP IOC correlation. Cloud extension: AWS VPC flow logs (CloudWatch Logs), GCP VPC flow logs (Flow Analyzer), Azure NSG flow logs (Network Watcher) provide cloud network visibility. GCP Cloud Armor access logs capture WAF events. All cloud flow data forwarded to on-premises SIEM for unified threat hunting.	Advanced
Automation and Orchestration	Terraform defines network IaC with Git version control. Ansible configures firewall rules, routing tables, and VLANs. Pre-deployment validation prevents misconfigurations. Automated rollback via snapshots. Cloud extension: AWS Security Groups, GCP VPC firewall policy, Azure NSG rules all managed via Terraform IaC with Git. No ad-hoc cloud console network changes. Cloud	Advanced



	network configuration history in CloudTrail, GCP Audit Logs, Azure Activity Log.	
Governance	Network segmentation policies define VLAN assignments, firewall ACLs, traffic flows with automated enforcement. Encryption policies mandate TLS 1.3. Exception approvals documented with compensating controls. Cloud extension: cloud network policies documented : no public management ports, Tailscale-only access, provider-native default-deny. Cloud compliance audited via Wazuh SCA and cloud provider security tools (Security Hub, SCC security health, Defender for Cloud Secure Score).	Advanced
Gap to Optimal	Fully distributed micro-perimeters, dynamic just-in-time/just-enough connectivity, continuously evolving network rules based on real-time risk, enterprise-wide automated telemetry correlation. Cloud gaps: mTLS not fully deployed for cloud service-to-service communication.	Initial

5.4 Applications and Workloads (CISA ZTMM Table 5) : Maturity: Advanced

Subcategory	Implementation	Status
Application Access	Authentik OAuth2/OIDC authorization considers user identity, group membership, device compliance (Wazuh), source IP reputation, time-of-day restrictions, and MFA verification. Session-based access with 30-minute idle timeout. OAuth2 scopes limit permissions to minimum. Traefik middleware enforces path-based access control. Cloud extension: Tailscale ACL is the application access gate for cloud node management interfaces : explicit per-device, per-subnet allow rules required. Cloud console access governed by provider IAM with MFA. GuardDuty, SCC, Sentinel findings auto-create TheHive cases via Shuffle SOAR.	Advanced
Application Threat Protections	SafeLine WAF deploys OWASP CRS with 25% attack block rate (SQLi, XSS, command injection, path traversal). Traefik security headers (CSP, X-Frame-Options, HSTS). Suricata/Snort application-layer signatures. Rate limiting. Security testing via	Advanced



	OWASP ZAP and Burp Suite. Cloud extension: GCP Cloud Armor application-level WAF blocks SQLi/XSS via v33-stable expression sets. Azure DDoS Protection plan. AWS Security Hub surfaces application-layer misconfigurations.	
Accessible Applications	Cloudflare Tunnels expose internal services without port forwarding. Traefik provides public access with mandatory Authentik ForwardAuth. All public-facing applications protected by WAF and DDoS mitigation. Internal-only applications (monitoring, SIEM, PKI) isolated on private VLANs. Cloud extension: cloud node management interfaces accessible via Tailscale only : no public internet exposure. GCP Cloud Armor WAF/DDoS protects cloud-hosted public applications. Azure DDoS Protection plan homelab-ddos.	Advanced
Secure Application Development and Deployment	Infrastructure-as-Code (Terraform, Ansible) defines deployment environments with Git version control. Separate development, staging, and production environments. Docker images built from trusted base images with SHA-256 verification. Immutable container workloads with version-based updates. Developer SSH access restricted to non-production. Cloud extension: Azure ARM templates and cloud Terraform modules version-controlled in Git with PR review. Cloud node provisioning uses pre-validated Ansible playbooks : no ad-hoc configuration.	Advanced
Application Security Testing	Pre-deployment vulnerability scanning via OpenVAS and Nessus. Manual penetration testing for critical services. Dynamic testing via OWASP ZAP. Container image scanning planned (Trivy/Grype Q2 2026). Cloud extension: Wazuh SCA post-rebuild validates CIS baseline compliance for cloud nodes. AWS Inspector, GCP SCC, Azure Defender for Cloud provide cloud-native scanning. Cloud node rebuild timing validated against less than 2 hour RTO.	Advanced
Visibility and Analytics	Prometheus monitors application performance metrics. Uptime Kuma tracks 50+ services with multi-channel alerting. Application logs forwarded to SIEM. Cloud extension: AWS	Advanced



	CloudWatch Agent, GCP Cloud Monitoring Ops Agent, Azure Monitor VM metric alert rules (7 active). All cloud metrics visible in Checkmk on-premises dashboard.	
Gap to Optimal	Continuous real-time authorization incorporating behavior/usage patterns, immutable workloads with automated redeployment, automated security testing throughout SDLC. Cloud gaps: SBOM (Trivy/Grype) pending Q2 2026; CI/CD security scanning pipeline planned.	Initial

5.5 Data (CISA ZTMM Table 6) : Maturity: Advanced

Subcategory	Implementation	Status
Data Inventory Management	Filesystem monitoring tracks data repositories across 30+ hosts and 50+ containers. Database inventories document schemas and record counts. Backup inventories track encrypted archives. DNS logging provides data access pattern visibility. Egress filtering prevents unauthorized data transfer. DLP planning underway (Q2 2026). Cloud extension: cloud data inventory documented : AWS S3 CloudTrail buckets (SSE, 90-day lifecycle), GCP GCS buckets (default encryption), Azure Log Analytics homelab-log (90-day retention, encrypted at rest). Wazuh FIM monitors sensitive file paths on all 6 cloud nodes.	Advanced
Data Categorization	Sensitivity tiers (Public, Internal, Confidential, Restricted) defined with handling requirements. Filesystem metadata tags indicate sensitivity levels. Quarterly reviews update classifications. Cloud extension: cloud data categorized under same sensitivity tiers : CloudTrail and GCP Admin Activity logs (Confidential), Wazuh agent telemetry (Internal), Azure Log Analytics data per content type. Classification reviewed quarterly alongside on-premises.	Advanced
Data Availability	Dual SIEM (Splunk + Elastic) with 90-day hot, 1-year cold retention. Database replication. Backup retention: 4 weekly, 12 monthly, 7 yearly with offsite storage. High-availability services across multiple hypervisors. Cloud extension:	Advanced



	AWS S3 standard storage (99.999999999% durability). GCP Cloud Storage. Azure Log Analytics built-in geo-redundancy. Cloud node redundancy across 3 independent providers.	
Data Access	Authentik RBAC groups map to data repository permissions. Filesystem ACLs enforce least-privilege. Database role-based permissions. Session-based access with 30-minute timeout. Service account credentials rotated quarterly. Cloud extension: AWS IAM instance profiles enforce least-privilege data access (no wildcard actions). GCP service accounts with minimal roles. Azure RBAC per resource group. Tailscale ACL governs all cloud data access paths.	Advanced
Data Encryption	TLS 1.3 encrypts all network communications. AES-256-GCM encrypts backups (keys in Vaultwarden). SSH private keys encrypted. Database encryption-at-rest enabled. Ansible Vault encrypts secrets. Step-CA PKI with 90-day certificate rotation. Cloud extension: Tailscale WireGuard (ChaCha20-Poly1305) for all cloud management traffic. AWS S3 SSE for CloudTrail. GCP persistent disk and GCS default encryption. Azure Managed Disk and Log Analytics encrypted at rest. No plaintext management paths.	Advanced
Visibility and Analytics	SIEM correlation tracks data access patterns, failed authorization attempts, and anomalous queries. Wazuh FIM detects unauthorized modifications. Bandwidth monitoring identifies unusual upload volumes. Cloud extension: AWS CloudTrail DataEvent logging for S3 object access. GCP Data Access audit logs for GCS bucket access. Azure Monitor access logging for Log Analytics. Wazuh FIM on 6 cloud nodes. AWS VPC, GCP VPC, Azure NSG flow logs provide cloud data exfiltration visibility.	Advanced
Gap to Optimal	Formal DLP solution (planned Q2 2026), fully automated data categorization, encryption-in-use, robust predictive analytics. Cloud gaps: cloud egress filtering provides partial compensating control; formal DLP not yet deployed.	Initial



Cross-Cutting Capabilities (CISA ZTMM Table 7)

Capability	Implementation	Status
Visibility and Analytics (Cross-Cutting)	100% security event logging across DNS, SSH, Traefik, firewalls, endpoints, applications, and infrastructure forwarded to dual SIEM (Splunk + Elastic). Real-time correlation detects multi-stage attacks. Multi-source enrichment via MISP, Cortex, geolP databases. Behavioral baselines identify anomalies. Grafana: 20+ dashboards. Virtual environment monitoring: container lifecycle, VM provisioning, resource consumption anomalies. SIEM retention: 90-day hot, 1-year cold. Cloud extension: AWS CloudTrail, GCP Admin Activity/Data Access logs, Azure Activity Log/Monitor added as enterprise-wide collection sources. AWS VPC flow logs, GCP VPC flow logs, Azure NSG flow logs supplement on-premises pfSense data. Wazuh agents on 6 cloud nodes forward endpoint events to on-premises Splunk for unified correlation. GuardDuty, SCC, Sentinel behavioral analytics operate in parallel with on-premises SIEM. Gap: ML/UEBA not yet deployed for on-premises : cloud-native ML (GuardDuty, Sentinel) partially fills for cloud nodes.	Advanced
Automation and Orchestration (Cross-Cutting)	Shuffle SOAR orchestrates incident response (15+ playbooks) integrating TheHive, Cortex, MISP, and automated remediation. Wazuh Active Response provides automated containment (firewall-drop, account-disable, process-kill) with sub-30-minute MTTR. Terraform/Ansible IaC automates provisioning, configuration, and decommissioning. Automated patching: PatchMon, WSUS, Watchtower. Step-CA automated certificate lifecycle (90-day rotation). Multi-channel alerting: Discord, email, TheHive, PagerDuty. Cloud extension: Wazuh Active Response on 6 cloud nodes via Tailscale using same containment playbooks as on-premises. GuardDuty and Sentinel incidents auto-create TheHive cases via Shuffle SOAR webhook. Ansible cloud rebuild achieves RTO less than 2 hours. Cloud infrastructure changes	Advanced



	automated via Terraform IaC. Cloud node decommissioning runbooks documented. Gap: predictive analytics for proactive response; automated cloud network isolation without manual approval.	
Governance (Cross-Cutting)	Security policies documented with version control (Git) and quarterly reviews. CIS Benchmark baselines enforced via Wazuh SCA with automated compliance reporting (92-98%). Vulnerability remediation SLAs (Critical less than 72h, High less than 7d) via TheHive. Ansible enforcement with drift detection. Encryption policies mandate TLS 1.3 and modern algorithms. Least-privilege access control policies with automated quarterly reviews. Incident response policies with escalation criteria. Policy exceptions require documented compensating controls and annual re-approval. Cloud extension: cloud governance policies documented : no public management ports on any cloud instance, Tailscale-only management access, CIS SCA enforcement via Wazuh, IAM least-privilege per provider. AWS Security Hub, GCP SCC security health, Azure Defender for Cloud Secure Score provide cloud governance metrics. Cloud compliance visible in unified Wazuh SCA dashboard alongside on-premises. Gap: fully automated enterprise-wide policies with real-time adjustments; automated policy creation from threat intelligence.	Advanced

Zero Trust Maturity Summary

CISA Pillar	Maturity	Key Capabilities	Lab-Specific Evidence	Cloud Extension
Identity	Advanced	Phishing-resistant MFA, consolidated identity stores, automated risk assessment, need-based session access, automated analysis, integrated orchestration, enterprise-wide policies	Authentik SSO with TOTP MFA (100% admin accounts); OAuth2/OIDC across 90% web services; Splunk: failed auth, geolP, impossible travel; Wazuh account lifecycle monitoring; 30-minute	GuardDuty CredentialAccess findings; Sentinel new-location sign-in detection; GCP SCC IAM anomaly; SSH key-only Linux nodes; domain Kerberos for



			session timeouts; SSH cert auth via Step-CA; CIS password policies; quarterly access reviews	Windows nodes via Tailscale; cloud IAM least-privilege; 45-day dormancy review
Devices	Advanced	Verified compliance insights, automated asset tracking, device-aware access control, centralized threat protection, automated inventory/anomaly detection, enforcement mechanisms, enterprise-wide lifecycle policies	Wazuh: 25+ endpoints, 92-98% CIS compliance; Nessus monthly scans; PatchMon: 5,000+ packages, daily NVD; NetAlertX, Checkmk; container SHA-256 verification; non-compliant device quarantine; 50+ containers, 30+ VMs monitored	Wazuh CIS SCA on 6 cloud nodes daily (Amazon Linux, Debian 12/13, Ubuntu 22.04/24.04, Win Server 2025); PatchMon 4 Linux; WSUS 2 Windows; ClamAV + Defender; GuardDuty, SCC, Defender behavioral detection; RTO less than 2hr validated
Networks	Advanced	Endpoint/application isolation with micro-perimeters, dynamic risk-aware traffic management, full encryption with cryptographic agility, dynamic availability, anomaly-based detection, automated change management, tailored policies	3-tier VLAN architecture; pfSense CARP less than 5-second failover; TLS 1.3 via Traefik; Step-CA 90-day rotation; dual Unbound/Technitium DNS; 100% traffic visibility; Terraform IaC with Git; Ansible configures firewall rules, routing, VLANs	AWS VPC, GCP VPC, Azure VNet isolated from each other; Tailscale ACL default-deny; GCP Threat Intelligence blocking (TOR, malicious IPs, sanctioned countries); Cloud Armor WAF/DDoS; Azure DDoS Protection; cloud flow logs to SIEM
Applications and Workloads	Advanced	Automated access with contextual enforcement, integrated threat	Authentik OAuth2: identity, groups, device compliance, source IP, time-of-day,	Tailscale ACL gates cloud node access; GuardDuty, SCC,



		protections, most applications accessible with protection, distinct dev/sec/ops teams, integrated security testing, automated monitoring, tiered enterprise-wide policies	MFA; SafeLine WAF; OWASP CRS, 25% block rate; Traefik security headers; Cloudflare Tunnels; 50+ immutable containers; separate dev/staging/prod; OpenVAS, Nessus, OWASP ZAP scanning; Prometheus monitoring	Sentinel auto-create TheHive cases via Shuffle; GCP Cloud Armor app-layer WAF; Azure DDoS; Ansible rebuild RTO less than 2hr; ARM templates and Terraform IaC version-controlled
Data	Advanced	Automated enterprise-wide inventory with DLP, automated categorization, redundant highly-available stores, automated access controls with time limits, full encryption at rest/transit with cryptographic agility, enterprise-wide visibility, primarily automated lifecycle enforcement, integrated policy enforcement	Wazuh FIM: 30+ hosts, 50+ containers; dual SIEM: 90-day hot, 1-year cold; backup retention: 4 weekly, 12 monthly, 7 yearly offsite; sensitivity tiers: Public, Internal, Confidential, Restricted; AES-256-GCM backups; TLS 1.3 all communications; Authentik RBAC to data permissions; DNS logging	AWS S3 SSE CloudTrail (90-day); GCP disk default encryption; Azure Managed Disk + Log Analytics encrypted at rest; Tailscale WireGuard for cloud mgmt; Wazuh FIM 6 cloud nodes; cloud data classified; AWS CloudTrail DataEvent, GCP Data Access audit, Azure Monitor logging
Visibility and Analytics	Advanced	Automated enterprise-wide collection including virtual environments, centralized multi-source correlation, anomaly detection, threat hunting	Dual SIEM: 100% event coverage; real-time correlation multi-stage attacks; MISP, Cortex, geolP enrichment; behavioral baselines; Grafana 20+ dashboards; virtual environment monitoring; 90-day hot, 1-year cold retention	AWS CloudTrail, GCP Admin Activity/Data Access, Azure Activity Log added; VPC/NSG flow logs to SIEM; Wazuh agents on 6 cloud nodes forward to Splunk; GuardDuty, SCC,



				Sentinel behavioral analytics; cloud metrics in Checkmk
Automation and Orchestration	Advanced	Enterprise-wide automated orchestration/response, contextual information from multiple sources, IaC automation, SOAR workflows, automated patching, certificate lifecycle automation	Shuffle SOAR: 15+ playbooks, TheHive, Cortex, MISP; Wazuh Active Response: automated containment, sub-30-min MTTR; Terraform/Ansible IaC with Git; PatchMon, WSUS, Watchtower patching; Step-CA 90-day cert rotation; Discord, email, TheHive, PagerDuty alerting	Wazuh Active Response on 6 cloud nodes via Tailscale; GuardDuty and Sentinel auto-create TheHive cases via Shuffle; Ansible cloud rebuild RTO less than 2hr; Terraform/ARM template IaC; cloud decommissioning runbooks documented
Governance	Advanced	Tiered tailored policies enterprise-wide with automation, contextual access decisions, version-controlled policies, quarterly reviews, automated compliance reporting	Security policies in Git with quarterly reviews; Wazuh SCA: 92-98% CIS compliance; Critical less than 72h, High less than 7d SLAs via TheHive; Ansible enforcement with drift detection; TLS 1.3 + modern cipher enforcement; least-privilege policies; IR escalation criteria documented; compensating controls for exceptions	Cloud policies: no public ports, Tailscale-only access, Wazuh CIS SCA, IAM least-privilege per provider; AWS Security Hub, GCP SCC security health, Azure Defender Secure Score; cloud compliance in unified Wazuh dashboard

Overall CISA Zero Trust Maturity: Advanced (Stage 3 of 4): 87% of functions at Advanced or higher. Version 2.0 cloud integration (AWS, Azure, GCP - 6 nodes) strengthens evidence across all 5 pillars and 3 cross-cutting capabilities without changing the overall maturity rating.



Version History

Version	Date	Changes
1.0	January 2026	Initial assessment and summary statistics.
2.0	April 2026	Cloud IaaS integration (AWS, Azure, GCP - 6 nodes total). Cloud content integrated